

Clase 319 — Análisis avanzado de phishing y correo malicioso

Parte: **17 — Profundización para certificaciones** · Fuente: *Blue Team Level 1 (BTL1) — Phishing Analysis · CompTIA Security+ (SY0-701)* 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Analizar correos sospechosos como lo hace un analista SOC: leer **cabeceras**, verificar autenticación **SPF/DKIM/DMARC**, examinar **URLs y adjuntos** de forma segura, hacer **triaje** por indicadores y ejecutar la **respuesta** (contención, purga, bloqueo, reporte). Es una clase defensiva alineada con el módulo de *Phishing Analysis* de BTL1 y el dominio de amenazas de Security+.

⚠️ **Ética y seguridad:** todo análisis de adjuntos/URLs maliciosos se hace en una **VM aislada, sin red o con red controlada**, sobre muestras propias o de laboratorios autorizados. Nunca abras un adjunto sospechoso en tu equipo de trabajo ni visites la URL con tu navegador real.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Leer** cabeceras de correo (`Received` , `Return-Path` , `Authentication-Results` , `Message-ID`) para reconstruir la ruta y detectar suplantación.
2. **Interpretar** los resultados de SPF, DKIM y DMARC y explicar por qué un mensaje puede "pasar" SPF pero seguir siendo phishing.
3. **Analizar** URLs (defanging, redirecciones, homoglyphs) y adjuntos (hash, sandbox, análisis estático) sin ejecutarlos peligrosamente.
4. **Triar** correos por severidad y clasificar el tipo (spear phishing, BEC, credential harvesting, malware).
5. **Ejecutar** un playbook de respuesta: contención, purga multi-buzón, bloqueo de IOCs y reporte.

Temas

#	Tema	Por qué importa
1	Anatomía de un correo y sus cabeceras	La verdad del origen está en las cabeceras, no en el "De:" visible
2	SPF, DKIM, DMARC	Mecanismos de autenticación del remitente
3	Spoofing vs impersonation vs lookalike domains	Distintas técnicas de suplantación
4	Análisis de URLs (defanging, sandbox de URL)	Las URLs llevan a robo de credenciales o descargas
5	Análisis de adjuntos (hash, static, sandbox)	Los adjuntos entregan malware
6	Tipos: phishing, spear, whaling, BEC	Cambian impacto y respuesta
7	Triaje e IOCs	Priorizar y extraer indicadores para bloqueo
8	Respuesta y playbook	Contener, purgar, bloquear, reportar, concienciar

Definiciones y características

- **Cabeceras de correo:** metadatos del mensaje. `Received` (saltos MTA, se leen de abajo hacia arriba), `Return-Path` (dónde rebotan), `Authentication-Results` (veredicto SPF/DKIM/DMARC), `Message-ID`. Característica clave: revelan el origen real y la ruta, difíciles de falsificar todos a la vez.
- **SPF (Sender Policy Framework):** registro DNS TXT que lista qué IPs pueden enviar por un dominio. Verifica el **envelope-from** (Return-Path). Característica clave: valida IP de envío, **no** el "De:" visible → puede pasar y seguir siendo fraude.
- **DKIM (DomainKeys Identified Mail):** firma criptográfica de partes del mensaje verificable con clave pública en DNS. Característica clave: prueba integridad y que el dominio firmante autorizó el envío.
- **DMARC:** política que **aline**a el dominio del "De:" visible con SPF y/o DKIM e indica qué hacer si falla (`none` / `quarantine` / `reject`), más reportes. Característica clave: cierra el hueco de SPF/DKIM al exigir alineación con el remitente visible.
- **Defanging:** neutralizar un IOC para compartirlo sin riesgo de clic accidental: `hxxp://maLo[.]com`, `1.2.3[.]4`. Característica clave: seguridad al documentar.
- **Homoglyph / lookalike domain:** dominio visualmente similar (`paypa1.com`, `rnicrosoft.com`, IDN con cirílico). Característica clave: engaña la lectura rápida; se detecta con punycode/whois.
- **BEC (Business Email Compromise):** fraude sin malware que suplanta a un ejecutivo/proveedor para desviar pagos. Característica clave: alto impacto financiero, a menudo sin enlaces ni adjuntos, difícil de detectar por filtros.
- **IOC (Indicator of Compromise):** dato observable (URL, dominio, IP, hash, remitente) para detección y bloqueo. Característica clave: se extrae del análisis y alimenta a EDR/proxy/mail gateway.

Herramientas y preparación

Laboratorio aislado para análisis seguro:

- **VM aislada** (VirtualBox/Hyper-V, red host-only o sin red) para detonar adjuntos.
- **Análisis de cabeceras:** `Google Admin Toolbox Messageheader` o MXToolbox; visor de `.eml` / `.msg`.

- **URLs/archivos:** [VirusTotal](#), [URLScan.io](#), [Any.Run](#) o [Joe Sandbox] para detonación en sandbox.
- **Hashing:** `sha256sum` / `Get-FileHash` para huella del adjunto (comparte el hash, no el archivo).
- **Inspección de DNS:** `dig TXT dominio` para leer SPF/DMARC; `nslookup`.
- **Extracción:** `oletools` (`olevba`) para macros de Office, `pdfid` / `pdf-parser` para PDFs, [CyberChef](#) para decodificar/defang.

Nunca subas a servicios públicos (VirusTotal) documentos con datos sensibles reales; comparte hashes cuando el archivo pueda ser confidencial.

Laboratorio guiado — Análisis y triaje de un correo sospechoso

Ejercicio aplicado: analizarás un correo de phishing de muestra de laboratorio de punta a punta y producirás un informe de triaje con IOCs y respuesta.

1. **Obtén la muestra en crudo.** Descarga el `.eml` / `.msg` (muestra de laboratorio, p. ej. de PhishTank o un ejercicio BTL1). Ábrelo como texto, no en el cliente de correo.
2. **Analiza cabeceras.** Pega las cabeceras en Messageheader. Reconstruye los saltos `Received` (de abajo hacia arriba), identifica la IP de origen real y compara `From:` visible vs `Return-Path`.
3. **Verifica autenticación.** Lee `Authentication-Results`: ¿SPF pass/fail? ¿DKIM pass/fail? ¿DMARC alineado? Confirma consultando `dig TXT dominio` y `dig TXT _dmarc.dominio`.
4. **Evalúa el remitente.** Revisa si es spoofing (SPF fail), dominio lookalike (compara letra por letra, convierte IDN a punycode) o cuenta legítima comprometida.
5. **Analiza URLs sin hacer clic.** Extrae los enlaces del cuerpo, defang (`hxxp://...[.]...`), síguelos en [URLScan.io](#)/[VirusTotal](#) y observa redirecciones y la página final (¿formulario de credenciales?).
6. **Analiza el adjunto (en VM aislada).** Calcula su SHA-256, búscalo en VirusTotal. Si es Office, ejecuta `olevba` para ver macros; si es PDF, `pdfid`. Detona en sandbox (Any.Run) solo si es muestra autorizada.
7. **Clasifica y tría.** Determina tipo (credential harvesting, malware, BEC) y severidad (¿cuántos usuarios lo recibieron? ¿alguien hizo clic?).
8. **Extrae IOCs.** Lista remitente, IP, dominios, URLs y hashes en formato defanged.
9. **Ejecuta el playbook de respuesta.** Documenta: purga del correo en todos los buzones (búsqueda por Message-ID/asunto), bloqueo de IOCs en mail gateway/proxy/EDR, reseteo de credenciales si hubo clic, y aviso a usuarios.
10. **Redacta el informe.** Resumen, veredicto, evidencia de cabeceras/autenticación, IOCs y acciones tomadas.

Entregable: informe de análisis con veredicto, tabla de IOCs (defanged) y acciones de respuesta.

Ejercicios

1. Dadas unas cabeceras, indica la IP de origen real y si el `From:` fue suplantado.
2. Explica un caso donde SPF pasa pero DMARC falla, y por qué.
3. Convierte tres URLs y dos IPs a formato defanged y decodifica una URL con parámetros en Base64 usando CyberChef.
4. Compara `microsoft.com` con tres dominios lookalike y détéalos vía punycode.
5. Redacta el playbook de respuesta a un BEC que solicita un cambio de datos bancarios a un proveedor.

6. Extrae los IOCs de una muestra y escríbelos en una tabla lista para importar a un bloqueo.



Reto verificable

Reto: entrega el informe de análisis completo de un correo de phishing de muestra, con veredicto justificado, tabla de IOCs defanged y plan de respuesta.

Criterio de aceptación:

- Se determina la IP/origen real desde las cabeceras y se contrasta `From:` vs `Return-Path`.
- Se interpretan correctamente SPF, DKIM y DMARC (incluyendo el caso "SPF pass pero DMARC fail").
- Todos los IOCs se presentan **defanged**; ningún enlace vivo en el informe.
- El plan de respuesta incluye contención (purga), bloqueo de IOCs y acción sobre usuarios afectados.
- El análisis de adjunto/URL se hizo en entorno aislado (queda documentado).



Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"SPF pasó, así que es legítimo"	SPF valida el envelope-from, no el <code>From:</code> visible. Verifica alineación DMARC antes de concluir.
"Abrí el adjunto para ver qué era"	Detonación en el equipo real. Usa siempre VM aislada o sandbox; comparte hash, no el archivo.
"Pegué la URL viva en el informe"	Riesgo de clic accidental. Defang todos los IOCs (<code>hxxp</code> , <code>[.]</code>).
"Leí los <code>Received</code> de arriba hacia abajo"	Se leen de abajo hacia arriba : el salto inferior es el origen.
"Confundo dominio real con lookalike"	Homoglyphs/IDN. Convierte a punycode y compara carácter por carácter.
"Purgué solo mi buzón"	El correo llegó a muchos. Haz búsqueda y purga multi-buzón por Message-ID/asunto.



Preguntas frecuentes

? Si DMARC está en `p=reject`, ¿ya no necesito analizar correos? No. DMARC reduce el spoofing del propio dominio, pero no detiene lookalike domains, cuentas legítimas comprometidas ni BEC desde dominios externos. El análisis manual sigue siendo necesario.

? ¿Por qué un correo puede pasar SPF y aun así ser phishing? Porque SPF valida la IP frente al dominio del `Return-Path`, que el atacante controla. Si envía desde un dominio propio con SPF válido pero falsifica el `From:` visible, SPF pasa; solo DMARC (alineación) lo atrapa.

? ¿VirusTotal es seguro para cualquier adjunto? Cuidado: lo que subes queda disponible para otros suscriptores. Si el archivo puede contener datos confidenciales, busca por **hash** en vez de subir el archivo.

? ¿Qué es lo primero en un triaje? Determinar alcance (cuántos recibieron/hicieron clic) y si hubo compromiso de credenciales. Eso define la urgencia de la contención antes de profundizar en el análisis

forense.

Referencias

- Security Blue Team. *BTL1 — Phishing Analysis* — securityblue.team.
- RFC 7208 (SPF), RFC 6376 (DKIM), RFC 7489 (DMARC) — datatracker.ietf.org.
- M3AAWG. *Best Practices* y DMARC.org — dmarc.org.
- CISA. *Avoiding Social Engineering and Phishing Attacks* — cisa.gov.
- CompTIA. *Security+ SY0-701 Objectives* — dominio de amenazas y ataques.

Siguiente clase

[Clase 320 - Gobierno, aspectos legales/regulatorios y gestión del programa](#)